User Requirement Specification (URS)

Modular Chilled-Water Cooling Plant with Building Management System Integration

ISA/IEC 62443 Target Security Level 3 (SL-T 3)

Template with worked example

Worked example: data center plant — Trane Symbio 800 chiller modules · Rockwell ControlLogix 5580 plant control · Siemens Desigo CC BMS

Field	Value
Document number	**[URS-CHW-001]**
Revision	**[A — issued for review]**
Facility	**[DC-01 data center, chilled-water plant]**
Asset owner	**[Owner organization]**
System integrator	**[Integrator organization]**
Prepared by	**[Name, role]**
Date	**[DD Month YYYY]**
Data classification	**[Business Confidential]** (example marking)

Product capability statements in this document are as of 28 October 2026. Certifications and advisories change; confirm them at FAT, SAT and handover (URS-V-008).

Using this template

- Black text is the template requirement and applies to any modular chilled-water plant integrated with a BMS at SL-T 3.
- *Blue italic text is the worked example (data center; Trane, Rockwell and Siemens stack). Replace or delete it for your project.*
- **[Bracketed blue text]** is a project fill-in; the value shown is the worked-example default.
- “Shall” = mandatory (M). “Should” = desirable (D). Verification: I = inspection, A = analysis, D = demonstration, T = test.
- Requirement IDs are permanent once issued. Each requirement is one row with one ISA/IEC 62443 reference; requirements are never merged. The FRS traces every URS ID (Annex C).
- This template is open source, with no copyright. The Business Confidential marking in the header and footer is an example of applying the owner’s data-classification scheme to a specification that holds security design detail; replace it with the owner’s own label.
- This URS states what the owner needs, not how it is built. Product names in the worked example illustrate that the requirement is achievable and where gaps exist; selection is confirmed in the SDS and HDS.

Approvals

Role	Name	Signature	Date
Asset owner — facility operations	**[Name]**		**[Date]**
Asset owner — OT cybersecurity	**[Name]**		**[Date]**
Asset owner — facilities / mechanical engineering	**[Name]**		**[Date]**
System integrator (acknowledgement)	**[Name]**		**[Date]**

Revision history

Rev	Date	Description	Author
[A]	**[Date]**	**[Initial issue for review]**	**[Name]**

Contents

1 Purpose and scope
2 References, terms and abbreviations
3 System overview
4 Consequence and threat basis
5 Process and operational requirements
6 Zones, conduits and target security levels
7 System security requirements — ISA/IEC 62443-3-3 at SL-T 3
8 Component security requirements — ISA/IEC 62443-4-2 at SL-C 3
9 Supplier and lifecycle requirements
10 Verification and acceptance
Annex A Worked example — product capability snapshot
Annex B Requirement count
Annex C Traceability matrix
Annex D Open items to confirm with vendors

1 Purpose and scope

1.1 Purpose

This URS defines the owner's process, operational and cybersecurity requirements for a modular chilled-water cooling plant and its integration with the building management system (BMS). Cybersecurity requirements are stated against ISA/IEC 62443-3-3 system requirements and ISA/IEC 62443-4-2 component requirements at a target security level of 3 (SL-T 3) — protection against intentional violation using sophisticated means with moderate resources, IACS-specific skills and moderate motivation.

It is the first document in the specification chain URS → FRS → SDS and HDS → FAT → SAT / V&V. Every later document traces back to the IDs in this URS.

1.2 In scope

- Chiller modules and their unit controllers, pump modules, cooling tower cells, waterside economizer, thermal energy storage and vendor packages connected to the plant.
- Plant control system (controllers, I/O, drives, instruments, gateways) and the plant control network.
- Plant electrical metering used for monitoring and energy reporting.
- BMS supervisory functions for the plant (servers, clients, integration interfaces).
- Engineering workstations and tools, OT infrastructure services (identity, time, logging, backup, PKI, monitoring) and the industrial DMZ serving the plant.
- Remote access for owner staff and vendors.

1.3 Out of scope

- IT equipment and IT networks served by the plant (treated as untrusted networks).
- Electrical distribution protection and control beyond monitoring (separate EPMS specification).
- Fire alarm and life-safety system internals (hardwired interfaces only are in scope, see URS-P-052).
- Internal design of vendor package controllers beyond their interface, accounts and security configuration.

2 References, terms and abbreviations

2.1 References

Use the edition current at contract award unless the project states otherwise.

Reference	Title	Used for
ISA/IEC 62443-2-1	Security program requirements for IACS asset owners	Owner security program
ISA/IEC 62443-2-4	Security program requirements for IACS service providers	Integrator obligations
ISA/IEC 62443-3-2	Security risk assessment for system design	Zones, conduits, SL-T
ISA/IEC 62443-3-3	System security requirements and security levels	Section 7
ISA/IEC 62443-4-1	Secure product development lifecycle requirements	Supplier SDL
ISA/IEC 62443-4-2	Technical security requirements for IACS components	Section 8
ISA-TR84.00.09	Cybersecurity related to the functional safety lifecycle	Cyber-informed safety review
ANSI/ISA-18.2	Management of alarm systems for the process industries	Alarm philosophy
NIST SP 800-82 Rev. 3	Guide to OT security	Informative
ANSI/ASHRAE 135	BACnet (incl. BACnet Secure Connect)	BMS protocols
ANSI/ASHRAE 15	Safety standard for refrigeration systems	Refrigerant safety
ASHRAE TC 9.9	Thermal guidelines for data processing environments	Supply temperature basis
[Uptime Institute Tier Standard]	Topology (Tier III concurrently maintainable)	Redundancy basis
MITRE ATT&CK for ICS	Adversary techniques for ICS	Threat basis (section 4)

Reference	Title	Used for
MITRE EMB3D	Threat model for embedded devices	Device threats (FRS/SDS)
Vendor documents	As listed in Annex A for each product	Worked example

2.2 Terms

Term	Meaning
SL-T	Target security level for a zone or conduit, from the 62443-3-2 risk assessment.
SL-C	Capability security level a component or system can provide when properly configured.
SL-A	Achieved security level of the installed system, confirmed by V&V.
Zone / conduit	Grouping of assets sharing security requirements / the communication path between zones.
EDR / HDR / NDR / SAR	62443-4-2 component types: embedded device, host device, network device, software application.
Compensating countermeasure	A system-level control that meets a requirement a component cannot meet itself; recorded with residual risk.
IDMZ	Industrial demilitarized zone between the OT zones (L0–L3) and enterprise (L4).
Break-glass	Sealed emergency credential used when normal authentication is unavailable; use is audited.
V&V	Verification and validation of the installed system against this URS and the FRS.

2.3 Abbreviations

BMS building management system · CHW chilled water · CW condenser water · EWS engineering workstation · FAT/SAT factory/site acceptance test · HMI human-machine interface · MFA multifactor authentication · MOC management of change · PKI public key infrastructure · POA&M plan of action and milestones · RPO/RTO recovery point/time objective · SBOM software bill of materials · TES thermal energy storage · VFD variable frequency drive.

3 System overview

3.1 Facility and mission

The plant serves a **[4.8 MW IT load]** *data center. Loss of chilled water causes IT inlet temperatures to exceed ASHRAE allowable limits within minutes, forcing IT thermal shutdown. The plant is built from factory-tested modules (chiller, pump and tower skids) connected on site, so each module must remain controllable and maintainable on its own.*

3.2 Plant modules

Module	Qty	Redundancy	Control (worked example)
Water-cooled chiller module	**[4]**	N+1	*Trane chiller with Symbio 800 unit controller and TD7 display; local control of compressor, safeties and capacity.*
Chilled-water pump module	**[4]**	N+1	*Variable-speed pumps on PowerFlex 755T drives, controlled by the plant controller.*
Condenser-water pump module	**[4]**	N+1	*PowerFlex 755T drives, plant controller.*
Cooling tower cell	**[4]**	N+1	*Fan motors on Danfoss VLT HVAC Drive FC 102.*
Waterside economizer (plate heat exchanger)	**[2]**	N+1	*Valves and temperatures via plant controller I/O.*
Thermal energy storage tank	**[1]**	—	*Ride-through during chiller restart (URS-P-004).*
Water treatment skid (vendor package)	**[1]**	—	*Siemens SIMATIC S7-1500 skid PLC: PROFINET IO to remote I/O and dosing drives, PROFIBUS DP to legacy dosing pumps, PROFIBUS PA instruments via a DP/PA coupler; OPC UA to the BMS, Modbus TCP status to the plant controller.*
Refrigerant monitoring and leak detection panels	**[1]**	—	*Modbus RTU through a ProSoft / FieldServer QuickServer to BACnet/IP for BMS monitoring; all safety outputs hardwired.*

Module	Qty	Redundancy	Control (worked example)
Plant-room HVAC (ventilation, unit heaters)	[1]	—	*Siemens Desigo PXC automation station on BACnet/SC to Desigo CC; BACnet MS/TP to room-level controllers. Refrigerant-emergency ventilation stays hardwired (URS-P-050).*
Plant control panels	[2 (A/B)]	Per SDS	*ControlLogix 5580 plant controllers with I/O and Modbus TCP client modules.*
Electrical metering	[per feeder]	—	*PowerLogic PM8000 on chiller feeders; PM5560 on pump and tower MCC feeders.*

3.3 Reference architecture (L0–L5)

The architecture uses simple L0–L5 levels. The IDMZ sits between L3 and L4.

Level	Function	Assets and zones (worked example)
L0	Process	*Compressors, heat exchangers, pumps, tower fans, valves, temperature / pressure / flow sensors, refrigerant detectors (hardwired).*
L1	Basic control	*Symbio 800 (Z1-n); ControlLogix 5580 with I/O and MVI56E-MNET, PowerFlex 755T, FC 102, Proline Promag 300/500 (Z2); PM8000 / PM5560 (Z3); S7-1500 water-treatment skid with PROFINET and PROFIBUS devices, QuickServer and refrigerant panels (Z4); Desigo PXC and BACnet MS/TP controllers (Z10).*
L2	Supervisory	*Local plant operator interface (Z2); Desigo CC servers and clients (Z5).*
L3	Site operations and management	*Engineering workstations (Z6); OT directory, NTP, log collection, backup, PKI, network monitoring (Z7).*
IDMZ	Between L3 and L4	*Jump host with MFA and session recording, patch and AV staging, data replication (Z8).*
L4–L5	Enterprise and internet	*Enterprise IT, vendor cloud services (Trane Connect, Siemens cloud services) — untrusted, out of scope.*

3.4 Interfaces

Interface	Purpose and example protocol
Chiller module ↔ plant controller	*Enable, setpoint, status, alarms. Modbus TCP from Symbio 800 to the plant controller (MVI56E-MNET).*
Chiller module ↔ BMS	*BACnet/SC if Trane releases it for Symbio 800; otherwise BACnet/IP, read-only.*
Plant controller ↔ BMS	*Monitoring, alarms, bounded setpoint requests. Primary: ControlLogix 5580 native OPC UA server, SignAndEncrypt, to Desigo CC. Secondary: Kepware as the aggregate plant data historian path.*
Plant controller ↔ pump drives	*CIP EtherNet/IP with CIP Security (PowerFlex 755T).*
Plant controller ↔ tower fan drives and flowmeters	*CIP EtherNet/IP (FC 102 MCA 121 option; Proline 300/500); CIP Security confirmed per device; hardwired run and fault as backup.*
Water-treatment skid internal	*PROFINET IO to remote I/O and dosing drives; PROFIBUS DP to legacy dosing pumps; PROFIBUS PA instruments via DP/PA coupler.*
Water-treatment skid ↔ BMS and plant controller	*OPC UA SignAndEncrypt from the S7-1500: primary to Desigo CC, secondary to Kepware; Modbus TCP status and a hardwired summary trip to the plant controller.*
Refrigerant and leak panels ↔ BMS	*Modbus RTU → QuickServer → BACnet/IP, monitoring only.*
Plant-room HVAC ↔ BMS	*Desigo PXC on BACnet/SC to Desigo CC; BACnet MS/TP to room controllers.*
All plant subsystems ↔ Kepware (secondary)	*Read-only aggregation of every vendor subsystem into Kepware, the universal long-term site and campus-wide data historian path. Desigo CC stays the primary supervisory path.*
Meters ↔ BMS	*Read-only BACnet/IP (PM8000 FW 4.6+) or Modbus TCP (PM5560).*
BMS ↔ other systems (EPMS, DCIM)	*Through the IDMZ: OPC UA or BACnet/SC; HTTPS APIs.*
Hardwired safety	*Refrigerant detection, machine-room ventilation, fire alarm shutdown, chiller flow-proving — no network dependency.*
Remote access	*Owner and vendor access only through the IDMZ jump host.*

4 Consequence and threat basis

4.1 Security objectives

The plant's security objectives are availability, integrity, safety, resilience and continuity of the cooling process and the data center mission it supports. Confidentiality is protected where it supports these objectives (credentials, configurations, network design).

4.2 Consequences

ID	Consequence	Effect
CQ-1	Loss of cooling to the white space	IT thermal shutdown; outage of the hosted services (availability, continuity).
CQ-2	Undetected degraded cooling	Manipulated or false readings let temperatures drift; IT throttling or hardware damage (integrity).
CQ-3	Equipment damage	Chiller surge or freeze, pump dead-head, tower fan overspeed (property, resilience).
CQ-4	Personnel harm	Refrigerant release, rotating equipment, chemical exposure (safety).
CQ-5	Environmental release	Refrigerant or water-treatment chemical release (environment).
CQ-6	Loss of view or forensic record	Operators cannot see or reconstruct plant state (integrity, resilience).

4.3 Threat scenarios

Techniques are from MITRE ATT&CK for ICS. The FRS and SDS extend device-level threats with MITRE EMB3D.

ID	Scenario	MITRE ATT&CK for ICS	URS controls
TS-01	Adversary uses vendor or owner remote access to reach the plant and stop chillers or pumps.	T0822 External Remote Services; T0859 Valid Accounts; T0855 Unauthorized Command Message; T0826 Loss of Availability	URS-S-101, URS-S-113, URS-S-201, URS-S-502
TS-02	Compromised BMS client changes setpoints and hides the effect on graphics.	T0831 Manipulation of Control; T0836 Modify Parameter; T0832 Manipulation of View	URS-S-201, URS-S-305, URS-S-304, URS-S-208
TS-03	Malicious logic downloaded to the plant controller from an engineering workstation.	T0843 Program Download; T0889 Modify Program	URS-S-201, URS-S-304, URS-S-203, URS-S-212
TS-04	Tampered firmware loaded into a controller or drive.	T0839 Module Firmware; T0862 Supply Chain Compromise	URS-S-304, URS-D-E310, URS-D-E314, URS-L-010
TS-05	Default credentials on a gateway, meter or drive give write access.	T0812 Default Credentials; T0836 Modify Parameter	URS-S-105, URS-S-706
TS-06	Infected removable media used during maintenance.	T0847 Replication Through Removable Media	URS-S-203, URS-S-302
TS-07	Network flood on the plant network blocks control and view.	T0814 Denial of Service; T0813 Denial of Control; T0815 Denial of View	URS-S-701, URS-S-306, URS-P-013
TS-08	Alarms suppressed so a condenser-water failure goes unnoticed.	T0878 Alarm Suppression; T0827 Loss of Control	URS-S-304, URS-S-602, URS-P-031
TS-09	Cloud-connected or internet-exposed device used as the entry point.	T0883 Internet Accessible Device; T0886 Remote Services	URS-S-113, URS-S-707, URS-L-009
TS-10	Override or bypass functions (e.g., drive fire/emergency modes) misused to defeat equipment protection.	T0836 Modify Parameter; T0879 Damage to Property; T0880 Loss of Safety	URS-P-053, URS-S-201, URS-S-304

4.4 Basis for SL-T 3

The 62443-3-2 risk assessment for the worked example assigns SL-T 3 to the zones whose compromise can cause CQ-1, CQ-3 or CQ-4: an attacker with IACS knowledge and moderate resources (organized crime, hacktivists with OT skills, insider with engineering access) is credible against a data center. Zones whose compromise causes only CQ-2 or CQ-6 may carry a lower vector; the worked example sets the metering zone to SL-T 2. Project values: **[from the 62443-3-2 assessment]**.

5 Process and operational requirements

These requirements define the cooling service the security requirements protect. The FRS turns each into testable functions.

ID	Requirement	Worked example	M/D	Verif.
Capacity and redundancy				
URS-P-001	The plant shall deliver **[4,800 kW]** design cooling at **[design ambient and supply conditions]** with N+1 redundancy of chillers, chilled-water pumps, condenser-water pumps and tower cells.	*4 × 1,600 kW chiller modules, 3 duty + 1 standby.*	M	A/T
URS-P-002	Any single module, controller, network switch, power feed or boundary device shall be removable for maintenance without reducing capacity below design load (concurrent maintainability).	*Tier III basis; A/B plant control panels and redundant network paths.*	M	A/D
URS-P-003	The chilled-water supply setpoint shall be adjustable within **[15–20 °C]** with a default of **[18 °C]**.	*Warm-water design per ASHRAE TC 9.9 allowable range.*	M	T
URS-P-004	Thermal storage shall hold supply temperature within **[+2 K]** of setpoint for **[10 min]** at full load while chillers restart after a power interruption.	*CHW TES tank sized in the HDS.*	M	A/T
URS-P-005	The plant should maximize waterside economizer operation when condenser-water temperature allows.	*Plate heat exchangers with automatic changeover.*	D	T
Control and sequencing				
URS-P-010	The plant shall stage chillers, pumps and tower cells automatically on load, flow and temperature, with lead/lag rotation by run hours.	*Plant sequence in the ControlLogix plant controller.*	M	T
URS-P-011	On failure of a duty unit, the standby unit shall start automatically within **[60 s]** without operator action.		M	T
URS-P-012	Plant control logic shall reside in the plant control zone. The BMS shall supervise (monitor, alarm, trend, report) and may only request setpoints or modes inside limits enforced by the plant controller.	*Desigo CC has no direct write path to chiller or drive control points.*	M	I/T
URS-P-013	Each chiller module shall keep running safely under its own controller if communication with the plant controller is lost, using a defined default state.	*Symbio 800 local setpoint and enable behaviour defined in the FRS.*	M	T
URS-P-014	Operating modes (auto, manual per unit, maintenance lockout, economizer, emergency) shall require role authorization to change and every change shall be logged.		M	D
URS-P-015	Hardwired permissives and interlocks (flow proving, condenser flow, emergency stop) shall work without any network communication.		M	T
Degraded modes and resilience				
URS-P-020	Loss of the BMS supervisory zone shall not affect cooling delivery.		M	T
URS-P-021	Loss of the IDMZ, enterprise network or internet shall not affect cooling delivery or local operation.		M	T
URS-P-022	No single network component failure shall cause loss of control of more than one redundant unit.	*Ring or dual-path topology chosen in the SDS.*	M	A/T
URS-P-023	Controls, network equipment and supervisory servers shall be on UPS for **[15 min]** fed from a generator-backed source, and shall return automatically to the pre-event operating mode after power restoration.		M	T
URS-P-024	Every final element (valve, drive, chiller enable) shall have a defined fail state documented in the FRS.		M	I/T
Operator interface, alarms and trending				
URS-P-030	A local plant operator interface shall allow operation of the plant independent of the BMS.	*Product selected in the SDS.*	M	D
URS-P-031	The BMS shall provide plant graphics, prioritized alarms, trends and reports; alarm management shall follow **[ANSI/ISA-18.2]**.	*Desigo CC.*	M	D
URS-P-032	Key process values shall be trended at **[1 min]** resolution and retained for **[13 months]**.		M	D

ID	Requirement	Worked example	M/D	Verif.
URS-P-033	Security-relevant events that affect operation (communication loss, controller mode change, firmware or logic change, boundary island mode) shall be alarmed to operators.		M	T
Metering and energy				
URS-P-040	Electrical demand and energy shall be metered per chiller, per pump group and per tower group, and plant efficiency (kW/kW or kW/ton) shall be calculated.	*PM8000 and PM5560.*	M	T
URS-P-041	Thermal energy delivered shall be metered from chilled-water flow and temperature difference.	*Proline Promag 300/500 flowmeters.*	M	T
Safety-related functions				
URS-P-050	Refrigerant leak detection, alarm and machine-room ventilation shall comply with **[ANSI/ASHRAE 15 and local code]** and be hardwired, independent of any network; the BMS monitors only.		M	T
URS-P-051	Chiller internal protections (pressure, temperature, motor) shall remain under manufacturer control and shall not be overridable over any network.		M	I/T
URS-P-052	Fire alarm and life-safety shutdown signals to the plant shall be hardwired.		M	T
URS-P-053	Network-accessible functions that can defeat equipment protection (drive fire or emergency override modes, bypasses, forcing) shall be disabled or restricted to an authorized role, and their state shall be monitored and alarmed.	*Danfoss FC 102 Fire Mode (par. 24-0*) state monitored; ControlLogix forces alarmed.*	M	T
URS-P-054	A cyber-informed safety review following ISA-TR84.00.09 shall confirm that no network attack path can disable a safety protection.		M	A
Maintainability and lifecycle				
URS-P-060	Design life shall be **[15 years]**; components shall have vendor security support for the design life or a funded replacement plan.		M	A
URS-P-061	Spares shall be held at the approved firmware/software baseline.		M	I
URS-P-062	All control and security configuration changes after SAT shall follow management of change.		M	I
URS-P-063	Engineering changes shall be made only from owner-managed engineering workstations in the engineering zone.		M	I/D

6 Zones, conduits and target security levels

6.1 Requirements

ID	Requirement	M/D	Verif.
URS-Z-001	The integrator shall perform an ISA/IEC 62443-3-2 risk assessment and document zones, conduits, SL-T vectors and a cybersecurity requirements specification before detailed design; the owner approves them.	M	I
URS-Z-002	Every asset shall be assigned to exactly one zone; every communication path between zones shall be a documented conduit.	M	I
URS-Z-003	Conduits shall carry only the protocols, endpoints and directions listed in the conduit register; all other traffic shall be blocked.	M	T
URS-Z-004	Safety functions listed in URS-P-050 to URS-P-052 shall have no network dependency and are not assigned to a network zone.	M	I
URS-Z-005	Where both ends of a link support a secure protocol variant (OPC UA with signing and encryption, BACnet/SC, CIP Security, PROFINET Security Class 2 or 3, Modbus/TCP Security), it shall be used. Where they do not, the insecure protocol shall be confined to its zone or a single allowlisted conduit, write access limited to listed points, and the gap recorded with its compensating countermeasure.	M	I/T

6.2 Zones (worked example)

SL-T vectors are listed FR1 to FR7. Project values come from the 62443-3-2 risk assessment.

Zone	Name	Assets	SL-T vector	Consequence
Z1-n	Chiller module n (one zone per module)	*Symbio 800, TD7 display, chiller I/O and expansion modules.*	3,3,3,3,3,3,3	CQ-1, CQ-3, CQ-4
Z2	Plant control	*ControlLogix 5580, I/O, MVI56E-MNET, PowerFlex 755T, FC 102, Proline Promag, local operator interface, Stratix 5800.*	3,3,3,3,3,3,3	CQ-1, CQ-3
Z3	Plant electrical metering	*PM8000, PM5560 (monitoring only, no control authority).*	2,2,2,1,2,2,2	CQ-2, CQ-6
Z4	Vendor packages	*S7-1500 water-treatment skid with PROFINET remote I/O and PROFIBUS DP/PA devices; QuickServer gateway; refrigerant and leak-detection panels.*	3,3,3,3,3,3,3	CQ-3, CQ-5
Z5	BMS supervisory	*Desigo CC servers and clients on Windows Server / Windows 11, ESXi cluster, Kepware (secondary, aggregate site and campus-wide historian path).*	3,3,3,3,3,3,3	CQ-1, CQ-2
Z6	Engineering	*EWS (Windows 11) with Studio 5000, Tracer TU, MCT 10, DeviceCare, ION Setup.*	3,3,3,3,3,3,3	CQ-1, CQ-3
Z7	OT infrastructure and security management	*OT directory, NTP, log collector, backup, PKI, monitoring sensors, hypervisor and network management.*	3,3,3,3,3,3,3	All
Z8	Industrial DMZ	*Jump host, patch / AV staging, replication.*	3,3,3,3,3,3,3	Entry point
Z10	Plant-room HVAC (BMS field)	*Desigo PXC automation station and BACnet MS/TP room controllers; no safety function.*	2,2,2,1,2,2,2	CQ-3
Z9	Enterprise and external	*Enterprise IT, internet, vendor cloud.*	Untrusted	—

6.3 Conduits (worked example)

Conduit	Between	Data	Example protocols	Boundary
C1-n	Z1-n ↔ Z2	*Chiller enable, setpoint, status, alarms.*	*Modbus TCP 502 (no native security → compensated).*	*FortiGate / allowlist*
C2	Z2 ↔ Z5	*Plant data to BMS; bounded setpoint requests (primary). Read-only aggregation to Kepware (secondary).*	*OPC UA 4840 SignAndEncrypt — ControlLogix native server to Desigo CC; Kepware as secondary client.*	*FortiGate*
C3	Z6 ↔ Z1, Z2, Z3, Z4, Z10	*Engineering, backup, diagnostics.*	*CIP Security, TIA Portal secure PG communication, HTTPS, vendor tools.*	*FortiGate*
C4	Z3 ↔ Z5	*Meter readings (read-only).*	*BACnet/IP 47808 or Modbus TCP 502, read-only (no native security → compensated).*	*FortiGate*
C5	Z4 ↔ Z2	*Skid status to plant controller; listed writes only.*	*Modbus TCP 502 from the S7-1500 (no native security → compensated) + hardwired summary trip.*	*FortiGate*
C6	Z5, Z6, Z7 ↔ Z8	*Remote sessions, patches, replication.*	*RDP/HTTPS from jump host; HTTPS.*	*FortiGate pair*
C7	Z8 ↔ Z9	*Brokered access, update download, outbound reporting.*	*HTTPS, MFA.*	*FortiGate pair*
C8	Z7 ↔ all OT zones	*Time, logs, backup, authentication, monitoring.*	*NTP, syslog over TLS, LDAPS/RADIUS, SNMPv3.*	*FortiGate*
C9-n	Z1-n ↔ Z5	*Chiller data to BMS.*	*BACnet/SC 443 when available; else BACnet/IP 47808 read-only.*	*FortiGate*
C10	Z4 ↔ Z5	*Skid data to BMS; refrigerant and leak monitoring.*	*OPC UA SignAndEncrypt from the S7-1500 — primary Desigo CC, secondary Kepware; BACnet/IP from QuickServer, read-only.*	*FortiGate*
C11	Z10 ↔ Z5	*Plant-room HVAC supervision.*	*BACnet/SC (Desigo PXC node to Desigo CC hub).*	*FortiGate*
C12	Z5 ↔ Z8	*System-of-systems exchange with EPMS and DCIM; Kepware campus-wide historian aggregation.*	*OPC UA or BACnet/SC; HTTPS APIs.*	*FortiGate pair*

6.4 Protocols and their security (worked example)

Secure variants are used wherever both ends support them (URS-Z-005). The remaining protocols are what real subsystems and vendor packages use today; each is confined and compensated as shown.

Protocol	Where used	Native security	Requirement when used
OPC UA	*C2, C10, C12*	Application certificates, user authentication, Sign or SignAndEncrypt.	Use SignAndEncrypt with current security policies; deprecated policies disabled (URS-S-403).
BACnet/SC	*C9-n, C11, C12*	TLS 1.3 with mutual certificate authentication (hub and node).	Preferred for every BACnet device that supports it.
BACnet/IP	*C4, C9-n fallback, C10 (QuickServer)*	None.	Read-only where possible; BBMD and foreign-device registration limited to listed devices; conduit allowlist; monitored (URS-S-602).
BACnet MS/TP	*Inside Z10*	None (RS-485).	Trunks inside the zone and physically protected; the PXC is the only router to IP.
Modbus TCP	*C1-n, C4, C5*	None in common use (Modbus/TCP Security over TLS exists but is rarely supported).	Allowlisted endpoints; write function codes limited to listed registers where the boundary device can inspect them; range checks in the receiver (URS-S-305).
Modbus RTU	*Inside Z4 (refrigerant and leak panels)*	None (serial).	Physically protected wiring; the gateway is the only path out.
CIP EtherNet/IP	*Inside Z2*	CIP Security (TLS/DTLS, device identity).	CIP Security where both ends support it; otherwise confined to Z2 with switch ACLs.
PROFINET IO	*Inside Z4 (skid)*	PROFINET Security Classes: Class 1 basic measures incl. signed GSD files; Class 2 certificate-based authentication and integrity; Class 3 adds optional confidentiality. Device support is limited — confirm.	Skid network not routed; DCP and SNMP hardened; Class 2/3 where devices support it.
PROFIBUS DP / PA	*Inside Z4 (skid)*	None (serial fieldbus).	Segments and DP/PA coupler inside the locked skid panel; reachable only through the skid PLC.
Hardwired I/O	*Safety and backup signals*	Not applicable.	Used for every safety function and as backup for critical run and trip signals.

7 System security requirements — ISA/IEC 62443-3-3 at SL-T 3

One row per system requirement (SR). Each row includes the requirement enhancements (RE) that ISA/IEC 62443-3-3 adds at SL 3. SL-A 3 is achieved by the system as configured — zones and conduits, system-level countermeasures, secure configuration and the components' actual capabilities together — not by product certification. Where a component lacks a needed capability, a compensating countermeasure is recorded with residual risk (URS-C-002). Where a zone carries a lower SL-T (e.g., Z3 at SL-T 2), only the REs for that level apply in that zone.

ID	Ref.	Requirement name	User requirement (SL 3)	Worked example	Verif.
FR 1 — Identification and authentication control (IAC)					
URS-S-101	**SR 1.1**	Human user identification and authentication	The system shall identify and authenticate every human user on all interfaces that permit human access (BMS and HMI clients, web interfaces, engineering software, SSH/CLI, device web pages). SL 3 requires **RE1** unique identification and authentication (no shared operator, engineer or vendor accounts) and **RE2** multifactor authentication for human access from untrusted networks (URS-S-113). Where a local panel cannot authenticate individuals, physical access control and an attributed logbook shall compensate.	*Desigo CC and Windows hosts authenticate to an OT-only directory in Z7; FactoryTalk Security for Studio 5000; named Symbio UI accounts per technician; MFA on the IDMZ jump host. Chiller TD7 displays and drive keypads compensated by badge-controlled plant-room access.*	D/T
URS-S-102	**SR 1.2**	Software process and device identification and authentication	The system shall identify and authenticate software processes and devices that communicate across zones. SL 3 requires **RE1** unique identification and authentication of each device or process (e.g., certificate-based identity). Where a protocol has no device authentication, the conduit shall be limited to allowlisted endpoints and the gap recorded with its compensating countermeasure and residual risk.	*CIP Security device certificates (e.g., 1756-EN4TR module) between ControlLogix and the EWS / data server; OPC UA application certificates between the ControlLogix OPC UA server and Desigo CC, and for the secondary Kepware client. Modbus TCP and BACnet/IP to Symbio 800 have no device authentication → C1-n and C9-n limited to listed addresses and ports; PROFINET and PROFIBUS stay inside the water-treatment skid (compensating).*	T
URS-S-103	**SR 1.3**	Account management	The system shall let authorized users add, activate, modify, disable and remove accounts. SL 3 requires **RE1** unified account management across zones for every component that can integrate with it. Device-local accounts that cannot be centrally managed shall be held in an account register with owner, role and a review interval of **[90 days]**.	*OT Active Directory (two domain controllers, Windows Server 2026, Z7) for Desigo CC, Windows hosts and FactoryTalk; RADIUS/TACACS+ for FortiGate and Stratix. Local register for Symbio 800, FC 102 SCF accounts, meters and QuickServer.*	I/D
URS-S-104	**SR 1.4**	Identifier management	Identifiers shall be assigned per user, group, role or device, shall not be reused for a different person within **[24 months]**, and shall be disabled within **[1 business day]** of departure or role change.	*Vendor identifiers issued per named technician and per approved work window.*	I
URS-S-105	**SR 1.5**	Authenticator management	The system shall initialize, protect, change and revoke authenticators. All default and factory authenticators shall be changed or disabled before SAT and protected in storage and transit. SL 3 requires **RE1** hardware-protected storage (TPM, HSM or secure element) for credentials used by software processes.	*Defaults removed before SAT: QuickServer label password, PowerLogic meter defaults, FC 102 legacy 0-6* passwords (SCF enabled), switch and firewall bootstrap credentials. TPM 2.0 on ESXi and Windows hosts; device private keys in hardware where supported, otherwise a recorded gap.*	T
URS-S-106	**SR 1.6**	Wireless access management	Wireless access to any OT zone shall be prohibited unless the owner approves it. Where approved, wireless users and devices shall be identified and authenticated; SL 3 requires **RE1** unique identification and authentication.	*Symbio 800 Air-Fi, Wi-Fi module, cellular uplink and Bluetooth service options not fitted or disabled. No wireless in Z1–Z7.*	I/T
URS-S-107	**SR 1.7**	Strength of password-based authentication	The system shall enforce configurable password strength. SL 3 requires **RE1** password generation and lifetime restrictions for human users. Where a component cannot enforce the policy, the limitation and its compensating countermeasure shall be documented.	*OT domain policy: **[14]**-character minimum, history **[24]**. Numeric-only device codes (drive keypads, meter display passcodes) compensated by physical access control.*	T

ID	Ref.	Requirement name	User requirement (SL 3)	Worked example	Verif.
URS-S-108	**SR 1.8**	Public key infrastructure certificates	Where public-key authentication is used, certificates shall be issued and managed by an owner PKI (or approved provider) with defined issuance, renewal and revocation. Self-signed certificates shall not be used in production unless the owner accepts the risk in writing.	*Offline root CA and issuing CA in Z7; certificates for Desigo CC, Symbio UI, FortiGate, Stratix, PowerLogic web servers, CIP Security and OPC UA endpoints.*	I
URS-S-109	**SR 1.9**	Strength of public key authentication	The system shall validate certificate signature, validity, revocation status and trust chain, and map the authenticated identity to a user or device. SL 3 requires **RE1** hardware protection of private keys used for authentication.	*CRL published inside OT (Z7); no dependency on internet revocation services.*	T
URS-S-110	**SR 1.10**	Authenticator feedback	Authentication interfaces shall obscure authenticator feedback during entry.	*Checked on Symbio UI, Desigo CC, FortiGate, meter web pages and QuickServer FS-GUI.*	D
URS-S-111	**SR 1.11**	Unsuccessful login attempts	The system shall limit consecutive invalid login attempts (configurable count and lockout or delay). Lockout shall never prevent operators from monitoring and operating the plant during an event; an audited break-glass procedure shall exist.	*Domain accounts: **[5]** attempts, **[15]**-minute lockout. Operator consoles keep a view-only session; sealed break-glass credentials with dual sign-out.*	T
URS-S-112	**SR 1.12**	System use notification	A configurable system-use notification shall be shown before authentication on every interactive interface that supports one.	*Banner text approved by owner legal; components without banner support recorded.*	I
URS-S-113	**SR 1.13**	Access via untrusted networks	Access from untrusted networks (enterprise, internet, vendor cloud) shall be monitored, controlled and terminated in the IDMZ; there shall be no direct path to Z1–Z7. SL 3 requires **RE1** explicit per-session approval by an authorized owner role. Vendor cloud connectivity built into products shall be off unless approved, and if approved shall pass through owner boundary devices.	*Trane Connect and Siemens cloud connectors disabled by default. Vendor support via IDMZ jump host with MFA, time-boxed approval, session recording and on-demand disconnect.*	T
FR 2 — Use control (UC)					
URS-S-201	**SR 2.1**	Authorization enforcement	The system shall enforce authorizations for all human users on all interfaces using least privilege and separation of duties. SL 3 requires **RE1** authorization enforcement for all users (humans, software processes, devices), **RE2** permission mapping to roles and **RE3** a time-limited, audited supervisor override.	*Roles: Viewer, Plant Operator, Shift Supervisor, Plant Engineer, Controls Engineer, Security Administrator, Vendor Service. Desigo CC rights per role; FactoryTalk Security and Logix source protection; Symbio UI permissions; FC 102 SCF roles. Shift Supervisor override for manual chiller start/stop logged with reason.*	D/T
URS-S-202	**SR 2.2**	Wireless use control	The system shall authorize, monitor and restrict any approved wireless use. SL 3 requires **RE1** identification and reporting of unauthorized wireless devices transmitting in the plant's physical environment.	*Periodic RF survey of plant room and panels; wireless-capable options recorded in the inventory with their disabled state evidenced.*	D
URS-S-203	**SR 2.3**	Use control for portable and mobile devices	The system shall restrict portable and mobile devices (laptops, USB media, SD cards). SL 3 requires **RE1** checking a device's security status (owner-managed, scanned, patched) before it may connect.	*Only owner-managed laptops in Z6; USB media scanned before use; ControlLogix SD/USB and Symbio 800 USB service port controlled physically and logically.*	D
URS-S-204	**SR 2.4**	Mobile code	The system shall restrict mobile code (scripts, browser code, macros). SL 3 requires **RE1** an integrity check before mobile code executes.	*Application allowlisting on Windows hosts; Desigo CC and Symbio UI browser clients only on managed hosts; macros blocked on EWS.*	T
URS-S-205	**SR 2.5**	Session lock	Workstations and clients shall lock after **[15 min]** of inactivity or on request. Control-room operator consoles may lock to a view-only state that keeps alarms and plant status visible.		D
URS-S-206	**SR 2.6**	Remote session termination	Remote sessions shall end automatically after **[15 min]** of inactivity and shall be terminable on demand by an authorized local role.	*Jump-host and FortiGate session timeouts.*	D
URS-S-207	**SR 2.7**	Concurrent session control	The system shall limit concurrent sessions per interface and per account to a configurable number.	*One remote engineering session per controller at a time.*	D

ID	Ref.	Requirement name	User requirement (SL 3)	Worked example	Verif.
URS-S-208	**SR 2.8**	Auditable events	The system shall create audit records for access control, request errors, operating system events, control system events (setpoint, mode, command, alarm acknowledgement, override), backup and restore, configuration changes, potential reconnaissance and audit-log events, each with timestamp, source, category, type, identity and outcome. SL 3 requires **RE1** a centrally managed, system-wide audit trail.	*Desigo CC activity log, Logix controller log and change detection, Symbio 800 audit trail, FC 102 audit log (43-6*), FortiGate, switch and host logs forwarded to the log collector in Z7.*	T
URS-S-209	**SR 2.9**	Audit storage capacity	Audit storage shall hold **[12 months]** online and **[3 years]** archived. SL 3 requires **RE1** a warning when a configurable storage threshold is reached.		T
URS-S-210	**SR 2.10**	Response to audit processing failures	On audit processing failure the system shall alert personnel and keep essential functions running; audit failure shall never stop cooling.		T
URS-S-211	**SR 2.11**	Timestamps	Components shall timestamp audit records. SL 3 requires **RE1** synchronization to owner time sources, using authenticated time protocols where supported.	*Redundant GPS-disciplined NTP servers in Z7; Symbio 800, ControlLogix, drives, meters and hosts synchronized; components without NTP recorded.*	T
URS-S-212	**SR 2.12**	Non-repudiation	The system shall determine whether a given person performed an action that affects the plant or its security (setpoint change, override, program download, firmware update, security configuration change).		T
FR 3 — System integrity (SI)					
URS-S-301	**SR 3.1**	Communication integrity	The system shall protect the integrity of transmitted information. SL 3 requires **RE1** cryptographic integrity protection. Where a protocol cannot provide it, the conduit shall be confined to a dedicated path behind a boundary device and the gap recorded.	*OPC UA SignAndEncrypt on C2, C10 and C12; BACnet/SC on C9-n, C11 and C12; CIP Security in Z2 where supported; TLS 1.2+, SSH, SNMPv3 for management. Recorded gaps: Modbus TCP (C1-n, C4, C5), BACnet/IP (C4, C9-n fallback, QuickServer), BACnet MS/TP (Z10), Modbus RTU, PROFINET and PROFIBUS (Z4) — compensated per URS-Z-005.*	T
URS-S-302	**SR 3.2**	Malicious code protection	The system shall detect, report and mitigate malicious code. SL 3 requires **RE1** protection at entry and exit points (boundaries, removable media, file transfer) and **RE2** central management and reporting.	*Vendor-qualified endpoint protection or allowlisting on Desigo CC servers and EWS; FortiGate IPS/AV at IDMZ and BMS boundaries; media scanning; central console in Z7.*	T
URS-S-303	**SR 3.3**	Security functionality verification	The system shall support verification of security functions at FAT, SAT, after changes and periodically. SL 3 requires **RE1** automated verification mechanisms. Intrusive verification shall run only on isolated or representative systems with written authorization.	*Configuration compliance checks against the approved baselines.*	T
URS-S-304	**SR 3.4**	Software and information integrity	The system shall detect unauthorized changes to software, firmware, configuration and control logic. SL 3 requires **RE1** automated notification of integrity violations to defined roles.	*ControlLogix change detection alarmed in the BMS; Symbio 800 signed firmware; FC 102 integrity check (0-91) enabled and 0-92 SHA-256 recorded; host file-integrity monitoring; ESXi Secure Boot and TPM attestation.*	T
URS-S-305	**SR 3.5**	Input validation	The system shall validate syntax, range and context of inputs that affect control. Limits shall be enforced in the plant controller, not only in the HMI or BMS.	*Chilled-water supply setpoint accepted only within the FRS range; out-of-range BMS writes rejected and logged.*	T
URS-S-306	**SR 3.6**	Deterministic output	Outputs shall go to a predetermined state when normal operation cannot be maintained (communication loss, controller fault, attack).	*Chillers continue under Symbio 800 local control; valves hold; pump drives hold last speed or go to a defined minimum — per final element in the FRS.*	T
URS-S-307	**SR 3.7**	Error handling	Error conditions shall be identified and handled without revealing information an adversary could use.		T

ID	Ref.	Requirement name	User requirement (SL 3)	Worked example	Verif.
URS-S-308	**SR 3.8**	Session integrity	The system shall protect session integrity. SL 3 requires **RE1** invalidation of session identifiers on logout or termination and **RE2** unique session identifier generation, rejecting identifiers not issued by the system.	*Web interfaces of Desigo CC, Symbio UI, FortiGate, meters.*	T
URS-S-309	**SR 3.9**	Protection of audit information	Audit information and audit tools shall be protected from unauthorized access, modification and deletion.	*Logs forwarded off-device in near real time; collector access limited to Security Administrator; integrity-protected archive.*	T
FR 4 — Data confidentiality (DC)					
URS-S-401	**SR 4.1**	Information confidentiality	The system shall protect the confidentiality of information that requires explicit read authorization (credentials, project files, configuration backups, network drawings). SL 3 requires **RE1** protection at rest and in transit across untrusted networks.	*Encrypted Symbio 800 and FortiGate backups; project archives (.ACD and .L5X, Desigo CC, MCT 10) on encrypted storage in Z7; never sent by enterprise e-mail.*	I/T
URS-S-402	**SR 4.2**	Information persistence	Information requiring confidentiality shall be purged from components leaving service or being reused; where purge is not supported the component shall be physically destroyed.	*ControlLogix has no documented secure erase → destroy at decommission; drives, meters and gateways factory-reset then destroyed; host media sanitized.*	I
URS-S-403	**SR 4.3**	Use of cryptography	Cryptography shall use algorithms, key lengths and key management accepted by recognized standards; deprecated algorithms and suites shall be disabled.	*TLS 1.2 minimum (1.3 preferred); OPC UA Basic128Rsa15 and Basic256 not permitted; SNMPv1/v2c disabled.*	T
FR 5 — Restricted data flow (RDF)					
URS-S-501	**SR 5.1**	Network segmentation	Control networks shall be segmented from non-control networks, and critical control networks from each other. SL 3 requires **RE1** physical segmentation from non-control networks and **RE2** independence: the plant shall keep operating when non-control networks are lost.	*Dedicated plant fibre and switches; no shared physical switches with IT; plant operates with IDMZ and enterprise links cut.*	I/T
URS-S-502	**SR 5.2**	Zone boundary protection	Communications at zone boundaries shall be monitored and controlled. SL 3 requires **RE1** deny by default / allow by exception, **RE2** island mode (isolate a zone on demand or on detection) and **RE3** fail close. Island mode or boundary failure shall not stop cooling.	*FortiGate at each conduit; every rule justified in a rule register; island-mode playbook tested at SAT.*	T
URS-S-503	**SR 5.3**	General purpose person-to-person communication restrictions	The system shall prevent general-purpose person-to-person messages (e-mail, chat, social media, file sharing) from entering or leaving the control system. SL 3 requires **RE1** prohibition of all such communications.		T
URS-S-504	**SR 5.4**	Application partitioning	Data, applications and services shall be partitioned by criticality and zone.	*Desigo CC servers, EWS and infrastructure services on separate VMs and port groups; no VM from another zone on the same port group; hypervisor management only in Z7.*	I
FR 6 — Timely response to events (TRE)					
URS-S-601	**SR 6.1**	Audit log accessibility	Authorized users and tools shall have read-only access to audit logs. SL 3 requires **RE1** programmatic access (syslog, API) for the owner's monitoring function.		D
URS-S-602	**SR 6.2**	Continuous monitoring	Security mechanisms shall be monitored continuously to detect, characterize and report security breaches promptly.	*Passive OT network monitoring sensors on SPAN ports in Z1–Z5; FortiGate, host and switch logs; alerts to the owner's security operations function.*	D
FR 7 — Resource availability (RA)					

ID	Ref.	Requirement name	User requirement (SL 3)	Worked example	Verif.
URS-S-701	**SR 7.1**	Denial of service protection	Essential functions shall continue in degraded mode during a denial-of-service event. SL 3 requires **RE1** communication load management (rate limiting, storm control, control-plane protection) so supervisory traffic cannot starve control traffic.	*Stratix 5800 storm control and QoS; FortiGate DoS policies; chillers keep local control if the plant network is flooded.*	T
URS-S-702	**SR 7.2**	Resource management	Security functions shall be constrained so they cannot exhaust resources needed for control (CPU, memory, bandwidth, storage).		T
URS-S-703	**SR 7.3**	Control system backup	User-level and system-level information, including state and security configuration, shall be backed up without affecting operation. SL 3 requires **RE1** backup verification and **RE2** automated backup at a defined frequency (RPO **[24 h]**).	*Automated backups where supported (Symbio 800, Desigo CC, FortiGate, switches, ESXi host configuration); Logix .ACD and .L5X after every change; MCT 10 archive for FC 102; quarterly test restore on the test bench.*	T
URS-S-704	**SR 7.4**	Control system recovery and reconstitution	The system shall be recoverable to a known secure state within **[RTO per component class]**.	*Gold images, verified backups, on-site spares at approved firmware, recovery runbook per module.*	T
URS-S-705	**SR 7.5**	Emergency power	Transfer to and from emergency power shall not compromise the security state or security functions.	*Controls, network and servers on UPS; boundary policy held through transfer; components return to their configured security state after restart.*	T
URS-S-706	**SR 7.6**	Network and security configuration settings	Components shall be configured to documented, owner-approved security baselines. SL 3 requires **RE1** machine-readable reporting of current security settings.	*Baselines from the per-product ISA/IEC 62443 SL-3 checklists; exported configurations compared with baseline at SAT and after each change.*	I/T
URS-S-707	**SR 7.7**	Least functionality	Unnecessary functions, ports, protocols and services shall be disabled.	*Telnet, HTTP, FTP, SNMPv1/v2c off where possible; unused Symbio 800 protocols (LON, Air-Fi), ControlLogix web pages and unused USB/SD disabled; QuickServer cloud registration off.*	T
URS-S-708	**SR 7.8**	Control system component inventory	A current inventory of all components (hardware, firmware and software versions, location, zone, owner) shall be maintained, with SBOMs where available.		I

8 Component security requirements — ISA/IEC 62443-4-2 at SL-C 3

8.1 General component requirements

ID	Requirement	Worked example
URS-C-001	Every component shall have a documented capability security level (SL-C) for each applicable ISA/IEC 62443-4-2 component requirement, determined from what the component can actually do: a requirement-by-requirement mapping of features and configuration settings, supported by vendor documentation, configuration evidence and test results. Independent certification, where held, is supporting evidence. It is not required for a component to be SL-C 3 capable, and a certificate alone does not show that the configured system meets SL 3.	*Annex A records each product's SL-3-relevant capabilities from the per-product checklists, with certification status shown only as supporting evidence as of 28 October 2026.*
URS-C-002	The target is SL-C 3 for every applicable component requirement, including the requirement enhancements specified for SL 3, judged on capability. Where a component lacks a capability that SL 3 needs, the supplier shall disclose the gap and the integrator shall allocate a compensating countermeasure at system level (section 7) and record the residual risk for owner acceptance.	*Capability gaps per product are listed in Annex A (e.g., no device authentication on Modbus TCP or BACnet/IP). A certificate at a lower level (e.g., ControlLogix 5580 certified at SL 1) reflects the scope assessed, not a ceiling on what the configured system can achieve.*
URS-C-003	Components shall be developed and supported under an ISA/IEC 62443-4-1 secure development lifecycle; a certified lifecycle is preferred.	*Rockwell, Siemens (Desigo CC), Danfoss and Fortinet hold 4-1 certification; Trane cites a 4-1 SDLA for its connected offerings — confirm product scope (Annex D).*
URS-C-004	Where a component holds a certification, any configuration outside the certified conditions shall be recorded with its risk impact. Leaving the certified configuration does not by itself prevent the system from achieving SL 3.	*ControlLogix 5580: enabling OPC UA or controller redundancy is outside the scope of its 4-2 SL 1 certificate; the capability is assessed on its own merits.*
URS-C-005	Each component shall be classified as embedded device (EDR), host device (HDR), network device (NDR) or software application (SAR). Software and its host are separate components.	*Desigo CC (SAR) on Windows Server (HDR) on ESXi (HDR) = three components.*

8.2 Component requirements common to all component types

Each component shall meet each requirement below at SL-C 3 by capability, including the REs specified for SL 3 in ISA/IEC 62443-4-2, or the gap shall be handled per URS-C-002. Certification is supporting evidence, not a precondition. A ✓ marks the component types the requirement applies to.

ID	Ref.	Requirement name	What the owner expects	EDR	HDR	NDR	SAR
URS-C-101	**CR 1.1**	Human user identification and authentication	Unique authentication of human users on every component interface.	✓	✓	✓	✓
URS-C-102	**CR 1.2**	Software process and device identification and authentication	Device and process identity, certificate-based where supported.	✓	✓	✓	✓
URS-C-103	**CR 1.3**	Account management	Local account management and integration with central account management.	✓	✓	✓	✓
URS-C-104	**CR 1.4**	Identifier management	Identifiers by user, group, role or device.	✓	✓	✓	✓
URS-C-105	**CR 1.5**	Authenticator management	Change of all defaults; hardware-protected credential storage expected at SL-C 3.	✓	✓	✓	✓
URS-C-107	**CR 1.7**	Strength of password-based authentication	Configurable length, complexity and lifetime.	✓	✓	✓	✓
URS-C-108	**CR 1.8**	Public key infrastructure certificates	Accepts owner-issued certificates.	✓	✓	✓	✓
URS-C-109	**CR 1.9**	Strength of public key-based authentication	Full chain and revocation validation; hardware key protection expected at SL-C 3.	✓	✓	✓	✓
URS-C-110	**CR 1.10**	Authenticator feedback	Obscured entry.	✓	✓	✓	✓

ID	Ref.	Requirement name	What the owner expects	EDR	HDR	NDR	SAR
URS-C-111	**CR 1.11**	Unsuccessful login attempts	Configurable limit and lockout or delay.	✓	✓	✓	✓
URS-C-112	**CR 1.12**	System use notification	Configurable banner.	✓	✓	✓	✓
URS-C-114	**CR 1.14**	Strength of symmetric key-based authentication	Protected symmetric keys; hardware protection expected at SL-C 3.	✓	✓	✓	✓
URS-C-201	**CR 2.1**	Authorization enforcement	Role-based authorization with supervisor override.	✓	✓	✓	✓
URS-C-202	**CR 2.2**	Wireless use control	Wireless restricted or absent.	✓	✓	✓	✓
URS-C-205	**CR 2.5**	Session lock	Inactivity and manual lock.	✓	✓	✓	✓
URS-C-206	**CR 2.6**	Remote session termination	Inactivity and on-demand termination.	✓	✓	✓	✓
URS-C-207	**CR 2.7**	Concurrent session control	Configurable session limits.	✓	✓	✓	✓
URS-C-208	**CR 2.8**	Auditable events	Security and control events recorded with identity and outcome.	✓	✓	✓	✓
URS-C-209	**CR 2.9**	Audit storage capacity	Sized storage with threshold warning.	✓	✓	✓	✓
URS-C-210	**CR 2.10**	Response to audit processing failures	Alert without loss of essential functions.	✓	✓	✓	✓
URS-C-211	**CR 2.11**	Timestamps	Synchronized time source.	✓	✓	✓	✓
URS-C-212	**CR 2.12**	Non-repudiation	Attribution of human actions.	✓	✓	✓	✓
URS-C-301	**CR 3.1**	Communication integrity	Authenticated and integrity-protected communication.	✓	✓	✓	✓
URS-C-303	**CR 3.3**	Security functionality verification	Supports verification of security functions.	✓	✓	✓	✓
URS-C-304	**CR 3.4**	Software and information integrity	Detects and reports unauthorized software or configuration change.	✓	✓	✓	✓
URS-C-305	**CR 3.5**	Input validation	Validates inputs that affect control.	✓	✓	✓	✓
URS-C-306	**CR 3.6**	Deterministic output	Defined output state on fault.	✓	✓	✓	✓
URS-C-307	**CR 3.7**	Error handling	No exploitable information in error output.	✓	✓	✓	✓
URS-C-308	**CR 3.8**	Session integrity	Protected, unique, invalidated session identifiers.	✓	✓	✓	✓
URS-C-309	**CR 3.9**	Protection of audit information	Audit records protected from change and deletion.	✓	✓	✓	✓
URS-C-401	**CR 4.1**	Information confidentiality	Confidentiality at rest and in transit.	✓	✓	✓	✓
URS-C-402	**CR 4.2**	Information persistence	Purge capability for decommissioning.	✓	✓	✓	✓
URS-C-403	**CR 4.3**	Use of cryptography	Recognized algorithms; deprecated suites disabled.	✓	✓	✓	✓
URS-C-501	**CR 5.1**	Network segmentation	Supports segmentation (interfaces, VLANs, filtering).	✓	✓	✓	✓
URS-C-601	**CR 6.1**	Audit log accessibility	Read-only and programmatic log access.	✓	✓	✓	✓
URS-C-602	**CR 6.2**	Continuous monitoring	Supports continuous security monitoring.	✓	✓	✓	✓
URS-C-701	**CR 7.1**	Denial of service protection	Maintains essential functions under load.	✓	✓	✓	✓
URS-C-702	**CR 7.2**	Resource management	Security functions do not exhaust resources.	✓	✓	✓	✓
URS-C-703	**CR 7.3**	Control system backup	Backup of configuration and state with integrity verification.	✓	✓	✓	✓
URS-C-704	**CR 7.4**	Control system recovery and reconstitution	Recovery to a known secure state.	✓	✓	✓	✓
URS-C-706	**CR 7.6**	Network and security configuration settings	Configurable to baseline; reportable settings.	✓	✓	✓	✓

ID	Ref.	Requirement name	What the owner expects	EDR	HDR	NDR	SAR
URS-C-707	**CR 7.7**	Least functionality	Unneeded functions can be disabled.	✓	✓	✓	✓
URS-C-708	**CR 7.8**	Control system component inventory	Reports component identity and versions.	✓	✓	✓	✓

8.3 Component-type-specific requirements

Requirements that ISA/IEC 62443-4-2 defines only for a component type. Labels follow the 4-2 component-type sets; each requirement is its own row.

ID	Ref.	Requirement name	User requirement (SL-C 3)	Worked example
Embedded devices (EDR) — controllers, drives, meters, instruments				
URS-D-E204	**EDR 2.4**	Mobile code	Components that run or serve mobile code shall control its execution and check its integrity and authenticity before use, or shall not support mobile code.	*Symbio UI and PowerLogic web pages; ControlLogix web pages disabled.*
URS-D-E213	**EDR 2.13**	Use of physical diagnostic and test interfaces	Physical diagnostic and test interfaces (serial consoles, USB service ports, SD slots, JTAG) shall be protected from unauthorized use and their use monitored.	*Symbio 800 USB service port, drive keypads, ControlLogix USB/SD, meter ports behind locked doors with door-open alarms to the plant controller.*
URS-D-E302	**EDR 3.2**	Protection from malicious code	The component shall prevent installation and execution of unauthorized code.	*Signed firmware only (Symbio 800, ControlLogix, PowerFlex 755T).*
URS-D-E310	**EDR 3.10**	Support for updates	The component shall support updates and verify update authenticity and integrity before installation. Updates shall be applicable one module at a time without loss of cooling.	*Symbio 800 signed and encrypted firmware; ControlLogix signed firmware; drive firmware per vendor, applied module by module.*
URS-D-E311	**EDR 3.11**	Physical tamper resistance and detection	The component shall resist tampering and its enclosure or housing shall make tampering detectable; tamper indications shall be reported.	*Lockable enclosures with door switches; tamper-evident seals on meters and drive keypads.*
URS-D-E312	**EDR 3.12**	Provisioning product supplier roots of trust	The component shall provision and protect the supplier roots of trust used to verify its firmware and software.	*Vendor firmware signing keys anchored in the device; confirm per product (Annex D).*
URS-D-E313	**EDR 3.13**	Provisioning asset owner roots of trust	The component shall let the owner provision and protect its own roots of trust (owner CA certificates).	*Owner CA loaded for HTTPS and CIP Security where the product supports it.*
URS-D-E314	**EDR 3.14**	Integrity of the boot process	The component shall verify the integrity, and where supported the authenticity, of firmware and software during boot.	*Boot-time firmware verification where supported; gaps recorded per product.*
Host devices (HDR) — servers, workstations, hypervisors				
URS-D-H204	**HDR 2.4**	Mobile code	Components that run or serve mobile code shall control its execution and check its integrity and authenticity before use, or shall not support mobile code.	*Application allowlisting; signed PowerShell only on EWS and servers.*
URS-D-H213	**HDR 2.13**	Use of physical diagnostic and test interfaces	Physical diagnostic and test interfaces (serial consoles, USB service ports, SD slots, JTAG) shall be protected from unauthorized use and their use monitored.	*BIOS/UEFI password; unused USB disabled; server out-of-band management only in Z7.*
URS-D-H302	**HDR 3.2**	Protection from malicious code	The component shall prevent installation and execution of unauthorized code.	*Endpoint protection or allowlisting qualified by Siemens for Desigo CC and by Rockwell for Studio 5000.*
URS-D-H310	**HDR 3.10**	Support for updates	The component shall support updates and verify update authenticity and integrity before installation. Updates shall be applicable one module at a time without loss of cooling.	*OS and application patches from staging in the IDMZ after vendor qualification.*
URS-D-H311	**HDR 3.11**	Physical tamper resistance and detection	The component shall resist tampering and its enclosure or housing shall make tampering detectable; tamper indications shall be reported.	*Servers in locked racks; chassis intrusion alarm where supported.*

ID	Ref.	Requirement name	User requirement (SL-C 3)	Worked example
URS-D-H312	**HDR 3.12**	Provisioning product supplier roots of trust	The component shall provision and protect the supplier roots of trust used to verify its firmware and software.	*UEFI Secure Boot with vendor keys.*
URS-D-H313	**HDR 3.13**	Provisioning asset owner roots of trust	The component shall let the owner provision and protect its own roots of trust (owner CA certificates).	*Owner certificates in machine stores; owner Secure Boot policy where used.*
URS-D-H314	**HDR 3.14**	Integrity of the boot process	The component shall verify the integrity, and where supported the authenticity, of firmware and software during boot.	*UEFI Secure Boot and TPM measured boot; ESXi host attestation.*
Network devices (NDR) — switches, firewalls, gateways				
URS-D-N106	**NDR 1.6**	Wireless access management	Network devices with wireless capability shall uniquely identify and authenticate wireless users and devices, or wireless shall be disabled.	*No wireless on plant switches or firewalls.*
URS-D-N113	**NDR 1.13**	Access via untrusted networks	Network devices that provide access from untrusted networks shall monitor and control that access and support explicit approval of each access request.	*FortiGate IDMZ pair brokers all access from Z9 with per-session approval.*
URS-D-N204	**NDR 2.4**	Mobile code	Components that run or serve mobile code shall control its execution and check its integrity and authenticity before use, or shall not support mobile code.	*Management web UIs only from Z7 management hosts.*
URS-D-N213	**NDR 2.13**	Use of physical diagnostic and test interfaces	Physical diagnostic and test interfaces (serial consoles, USB service ports, SD slots, JTAG) shall be protected from unauthorized use and their use monitored.	*Console and USB ports on Stratix 5800 and FortiGate inside locked cabinets; SD card use controlled.*
URS-D-N302	**NDR 3.2**	Protection from malicious code	The component shall prevent installation and execution of unauthorized code.	*Signed IOS-XE and FortiOS images only.*
URS-D-N310	**NDR 3.10**	Support for updates	The component shall support updates and verify update authenticity and integrity before installation. Updates shall be applicable one module at a time without loss of cooling.	*Image authenticity verified before install; redundant path kept during upgrade.*
URS-D-N311	**NDR 3.11**	Physical tamper resistance and detection	The component shall resist tampering and its enclosure or housing shall make tampering detectable; tamper indications shall be reported.	*Locked network cabinets with door alarms.*
URS-D-N312	**NDR 3.12**	Provisioning product supplier roots of trust	The component shall provision and protect the supplier roots of trust used to verify its firmware and software.	*Vendor image-signing roots of trust.*
URS-D-N313	**NDR 3.13**	Provisioning asset owner roots of trust	The component shall let the owner provision and protect its own roots of trust (owner CA certificates).	*Owner CA for management HTTPS and RADIUS/TLS.*
URS-D-N314	**NDR 3.14**	Integrity of the boot process	The component shall verify the integrity, and where supported the authenticity, of firmware and software during boot.	*Secure boot / image validation at start-up.*
URS-D-N502	**NDR 5.2**	Zone boundary protection	Network devices at zone boundaries shall enforce deny-by-default rules, support island mode and fail closed.	*FortiGate deny-by-default policies, island mode and fail-close at every conduit.*
URS-D-N503	**NDR 5.3**	General purpose person-to-person communication restrictions	Boundary network devices shall be able to block general-purpose person-to-person communication protocols.	*FortiGate application control blocks e-mail, chat and file-sharing protocols at OT boundaries.*
Software applications (SAR) — BMS, engineering and integration software				
URS-D-S204	**SAR 2.4**	Mobile code	Components that run or serve mobile code shall control its execution and check its integrity and authenticity before use, or shall not support mobile code.	*Desigo CC browser and Flex clients only on managed hosts.*

ID	Ref.	Requirement name	User requirement (SL-C 3)	Worked example
URS-D-S302	**SAR 3.2**	Protection from malicious code	The application shall operate with, and be qualified for, the host's malicious-code protection, and protect itself where applicable (e.g., validation of imported files).	*Desigo CC and Studio 5000 operate with the vendor-qualified malicious-code protection on their hosts.*

9 Supplier and lifecycle requirements

ID	Requirement	M/D	Verif.
URS-L-001	Suppliers shall provide, for each component, a requirement-by-requirement ISA/IEC 62443-4-2 capability statement (which feature and configuration meets each CR and RE, and which are not met), with any certificates held as supporting evidence (URS-C-001), current at delivery.	M	I
URS-L-002	Suppliers shall follow an ISA/IEC 62443-4-1 secure development lifecycle; certification is preferred.	M	I
URS-L-003	The integrator shall deliver the 62443-3-2 risk assessment, zone and conduit drawings, SL-T vectors and cybersecurity requirements specification for owner approval before detailed design.	M	I
URS-L-004	The integrator should hold ISA/IEC 62443-2-4 service-provider capability (certification preferred).	D	I
URS-L-005	An SBOM (SPDX or CycloneDX) shall be provided for each software and firmware component and updated with each release.	M	I
URS-L-006	Suppliers shall notify the owner of vulnerabilities affecting supplied components within **[30 days]** of public disclosure, with remediation guidance, and shall maintain a public PSIRT advisory process.	M	I
URS-L-007	Security updates shall be available for **[10 years]** from SAT, or end of support shall be notified at least **[24 months]** in advance.	M	I
URS-L-008	Each component shall have hardening documentation: ports, protocols and services list; all default accounts and credentials; security configuration guide.	M	I
URS-L-009	Components shall have no undocumented accounts, remote access paths or hard-coded credentials. Cloud and remote connectivity shall ship disabled.	M	I/T
URS-L-010	Firmware and software shall be delivered from an authenticated source with signatures or published hashes, at the approved baseline version.	M	I
URS-L-011	Firewall rules shall be delivered in a rule register with business justification, owner and review date for every rule.	M	I
URS-L-012	As-built deliverables shall include network, zone/conduit and data-flow drawings, component inventory, account register, security baselines with exported configurations, and backup, restore and recovery runbooks.	M	I
URS-L-013	After SAT, changes shall follow management of change with a security impact review and re-verification of affected URS requirements.	M	I
URS-L-014	A decommissioning procedure shall cover account and certificate revocation and data purge or destruction (URS-S-402).	M	I
URS-L-015	Operators, engineers and administrators shall be trained on security functions, roles and the break-glass procedure.	M	D
URS-L-016	Hardware shall be bought through authorized channels with provenance records.	M	I

10 Verification and acceptance

ID	Requirement	M/D	Verif.
URS-V-001	A cybersecurity FAT shall run on an integrator test system that matches the design (same models and firmware) and shall cover every URS-S, URS-C and URS-D requirement.	M	T
URS-V-002	Intrusive testing (vulnerability scanning, credential attacks, fuzzing, load and DoS) shall run only at FAT or on isolated or representative systems with written authorization — never on the live plant.	M	I
URS-V-003	SAT and V&V on the installed plant shall be read-only by default: native read-only views, exports, show commands and photographs.	M	I
URS-V-004	Per-product ISA/IEC 62443 SL-3 checklists for each EDR, HDR, NDR and SAR shall be the basis of the V&V procedures. Each requirement shall be adjudicated Pass, Fail, Partial, N/A or Deferred; Partial requires a compensating control and a residual-risk statement.	M	I
URS-V-005	Evidence shall be named consistently, hashed with SHA-256 at collection and kept only on an encrypted evidence share; it shall never be e-mailed in cleartext, and device passwords shall never be saved in tool profiles.	M	I
URS-V-006	Safety interlocks shall be proven by functional test under site procedures; security testing shall not change safety configuration.	M	T

ID	Requirement	M/D	Verif.
URS-V-007	SAT shall demonstrate degraded modes with cooling maintained: loss of BMS, loss of IDMZ and enterprise, boundary island mode, loss of plant controller to chiller communications and power transfer.	M	T
URS-V-008	Vulnerability advisories for every component shall be re-checked at FAT, SAT and handover; installed versions shall be at or above the fixed releases.	M	I
URS-V-009	All Fail results shall be closed or carried in an owner-accepted POA&M before handover; the punch list shall be closed before SAT sign-off.	M	I
URS-V-010	A security assurance report shall be delivered at handover with executive summary, scope and purpose, top findings and mitigations, observations, detailed technical appendix (evidence) and references.	M	I

Annex A Worked example — product capability snapshot

Capabilities are drawn from the per-product ISA/IEC 62443 SL-3 checklist library plus vendor manuals and advisories checked on 28 October 2026. SL-3 capability is judged feature by feature against each CR; certification is shown only as supporting evidence and is reported exactly as published. Re-check at each project gate.

Product	Role · zone	Type	Certification — supporting evidence (as of 28 October 2026)	SL-3-relevant capabilities	Capability gaps vs SL 3 and compensating direction
Trane Symbio 800 (with TD7 display)	*Chiller module controller · Z1-n*	EDR	*No 62443-4-2 certificate found. Trane cites an ISA/IEC 62443-4-1 SDLA for its connected offerings — confirm it covers Symbio 800.*	*Per-user web accounts with granular permissions and audit trail; signed and encrypted firmware; encrypted backups (device, microSD, USB) and automated backup; web UI can be limited to HTTPS or disabled; Trane Connect is outbound-only TLS 1.2+ on 443; BTL-listed (B-AAC, B-RTR).*	*BACnet/IP and Modbus TCP integration lack device authentication and cryptographic integrity (SR 1.2, SR 3.1) → dedicated C1, firewall allowlist, writes bounded in the plant controller. Wireless and cellular options → not fitted (SR 1.6). USB service port → physical control (EDR 2.13). BACnet/SC support not confirmed. CISA-coordinated 2021 code-injection issue fixed in v1.00.0007 — re-check advisories.*
Rockwell ControlLogix 5580	*Plant controller · Z2*	EDR	*IEC 62443-4-2 SL 1 (standard controllers FW 32+; process, NSE, XT, K FW 33+). OPC UA and redundancy, if enabled, exclude the controller from the certification.*	*CIP Security (with a CIP Security-capable communication module such as 1756-EN4TR); FactoryTalk Security and Policy Manager; change detection; source and execution protection; signed firmware.*	*Capability assessed per CR against SL 3, not limited by the SL 1 certificate scope. Redundancy and OPC UA sit outside the certified configuration → record per C-004. No secure erase → destroy at end of life. Front USB and SD disabled.*
ProSoft MVI56E-MNET / MNETC	*Modbus TCP client to chillers · Z2*	EDR	*No 62443 certificate recorded.*	*Configured from ProSoft Configuration Builder (.ppf project).*	*Modbus TCP has no authentication or integrity → conduit restriction (C1). Protect the .ppf project as confidential (SR 4.1).*
Rockwell PowerFlex 755T	*CHW and CW pump drives · Z2*	EDR	*IEC 62443-4-2 SL-C 1 (TÜV Rheinland, announced Feb 2025).*	*CIP Security; configuration via Studio 5000 profile, DriveExecutive or HIM.*	*HIM keypad has no per-user authentication → physical control; drive parameters included in change detection and backup.*
Danfoss VLT HVAC Drive FC 102 (SW 8.0x)	*Cooling tower fan drives · Z2*	EDR	*Certified to IEC 62443-4-1 / 4-2 (TÜV, FC 102 v08.00); Danfoss states SL 1.*	*Security configuration file (SCF) with named accounts and roles; security settings group 0-9*; audit log 43-6*; firmware integrity check (0-91) and SHA-256 readout (0-92).*	*Legacy 0-6* passwords active unless SCF enabled; 0-91 defaults to no check; SNMP (12-83) enabled by default; Fire Mode (24-0*) is safety-significant (P-053); keypad power-up reset deletes the SCF → physical control.*
Endress+Hauser Proline Promag 300/500	*CHW flow / thermal metering · Z2*	EDR	*Not recorded in the library sheet — confirm with the vendor.*	*Configuration via FieldCare / DeviceCare save and restore (library sheet: Promag P300/P500); EtherNet/IP to the plant controller.*	*Confirm user roles, web server and protocol options for the chosen transmitter (Annex D).*
Schneider PowerLogic PM8000	*Chiller feeder metering · Z3*	EDR	*No 62443 certificate recorded.*	*Firmware 4.0+ Secure ION (TLS, port 7443); 4.5+ blocks downgrade; 4.6.0 adds BACnet (B-SS).*	*Default user accounts must be changed (S-105); SEVD-2023-129-03 fixed in 4.0.0; Z3 SL-T 2 with read-only conduit C4.*
Schneider PowerLogic PM5560	*MCC feeder metering · Z3*	EDR	*No 62443 certificate recorded.*	*Firmware 4.x: HTTPS (TLS 1.2), forced change of administrator password, session timeout, banner.*	*Modbus IP filtering off by default; display passcodes default 0; HTTP/HTTPS server toggle is all-or-nothing; SEVD-2021-159-02 fixed 2.8.3.*
Siemens SIMATIC S7-1500	*Water-treatment skid PLC · Z4*	EDR	*Confirm for the CPU and firmware supplied.*	*OPC UA server with certificate and user authentication; TLS-secured PG/HMI communication; CPU access protection levels; know-how and copy protection; HTTPS web server; PROFINET IO controller.*	*PROFINET and PROFIBUS segments have limited or no native security → kept inside the skid panel (URS-Z-005); Modbus TCP status link unauthenticated → C5 allowlist. Library sheet capture: TIA project and upload from device.*
Siemens Desigo PXC (PXC4 / PXC5 / PXC7)	*Plant-room HVAC automation station · Z10*	EDR	*Not stated by Siemens — confirm.*	*End-to-end BACnet/SC; BTL-listed; ABT project (library sheet).*	*BACnet MS/TP trunk has no native security → physical protection inside Z10; PXC is the only IP router.*

Product	Role · zone	Type	Certification — supporting evidence (as of 28 October 2026)	SL-3-relevant capabilities	Capability gaps vs SL 3 and compensating direction
ProSoft / FieldServer QuickServer PS-QS-3x10-F	*Refrigerant and leak panel gateway · Z4*	NDR	*No 62443 certificate found.*	*FS-GUI with admin and unique label password; HTTPS mode chosen at first login; TLS 1.3; lockout after failed logins; WAN-mode firewall on the second port.*	*No NTP, syslog or audit log documented → compensate at C5; cloud (Grid) remote access off; CVE-2024-45493 / -45494 fixed in 7.0.0.*
Rockwell Stratix 5800	*Plant and metering access switches · Z2, Z3*	NDR	*ISASecure CSA 1.0.0 Level 2 / exida SL-C 2 (Catalyst IE3x00 / Stratix 5800, IOS-XE 17.12.1 and later).*	*IOS-XE: AAA (RADIUS/TACACS+), SSH, SNMPv3, 802.1X, storm control, signed images, DLR/PRP options.*	*Assess IOS-XE features against SL-3 REs per CR (certificate covers the SL 2 scope assessed); gaps compensated at FortiGate boundaries.*
Cisco Catalyst 9300	*BMS and infrastructure core · Z5, Z7*	NDR	*No 62443 certificate recorded in the library sheet — confirm.*	*IOS-XE AAA, SSH, SNMPv3, MACsec, 802.1X, image authenticity checks.*	*Confirm certification; harden per checklist.*
Fortinet FortiGate (FortiOS 7.6)	*Zone boundaries and IDMZ · all conduits*	NDR	*IEC 62443-4-2 SL 4 announced Aug 2026 (FortiGate, FortiGate Rugged, FortiGate VM) and 4-1 ML 2 — confirm certificate scope.*	*Deny-by-default policies, OT application control and IPS, admin MFA, HA, encrypted configuration backups.*	*Certified at SL 4; carries most boundary compensations.*
Siemens Desigo CC V9	*BMS head-end · Z5*	SAR	*TÜV SÜD certificate IITS2 113879 0004 Rev. 01 (V6 and higher): IEC 62443-4-1 (ML3 profile) and 4-2. Siemens documentation states SL 2.*	*Role-based rights, activity log, encrypted client-server communication, BACnet/SC, BTL B-XAWS.*	*Map capability per CR against SL 3 (OI-02). July 2026 Siemens advisory covers V7/V8 (all) and V9 before V9.0 QU1 → require V9.0 QU1 or later; re-check.*
Microsoft Windows Server 2026	*Desigo CC servers, OT directory, jump host · Z5, Z7, Z8*	HDR	*No 62443 certificate.*	*AD, Credential Guard, BitLocker, Defender / allowlisting, Secure Boot and TPM.*	*Harden per the Windows Server checklist; vendor-qualified security tools only.*
Microsoft Windows 11	*EWS and operator clients · Z5, Z6*	HDR	*No 62443 certificate.*	*As above.*	*Harden per the Windows 11 checklist.*
VMware ESXi 8	*Virtualization hosts · Z5, Z7*	HDR	*No 62443 certificate.*	*Lockdown mode, Secure Boot and TPM attestation, role-based permissions, syslog.*	*Management only from Z7; separate port groups per zone (S-504).*
Rockwell Studio 5000 / FactoryTalk	*Engineering software · Z6*	SAR	*Covered by Rockwell 4-1 SDL; check per product.*	*FactoryTalk Security, source protection, audit.*	*Engineering only from Z6 EWS.*
Kepware	*Secondary path: universal long-term site and campus-wide aggregate data historian · Z5*	SAR	*Confirm.*	*OPC UA server and client with certificate security; multi-vendor drivers (OPC UA, BACnet, Modbus, EtherNet/IP).*	*Desigo CC is the primary supervisory path for every subsystem; Kepware is read-only toward plant devices unless a write is listed in the FRS. Capability per CR to confirm (OI-09).*

Annex B Requirement count

Section	Prefix	Count
5 Process and operational	URS-P	31
6 Zones and conduits	URS-Z	5
7 System security (62443-3-3)	URS-S	51
8.1 General component	URS-C-00x	5
8.2 Common component (62443-4-2)	URS-C	43
8.3 Component-type-specific (62443-4-2)	URS-D	30
9 Supplier and lifecycle	URS-L	16
10 Verification and acceptance	URS-V	10
Total		191

Annex C Traceability matrix

Every URS ID traces forward to at least one FRS requirement, a design reference and a FAT and SAT/V&V test. The FRS completes this matrix.

URS ID	FRS ID	SDS / HDS	FAT test	SAT / V&V	Status
URS-P-013	[FRS-CHL-004]	[SDS-4.2 / HDS-3.1]	[FAT-CHL-07]	[SAT-CHL-07]	[Open]
URS-S-102	[FRS-SEC-012]	[SDS-6.3]	[FAT-SEC-21]	[VV-EDR-1.2]	[Open]

Annex D Open items to confirm with vendors

ID	Party	Item
OI-01	Trane	Symbio 800: BACnet/SC availability and release; 62443-4-2 certification status or plans; whether the 4-1 SDLA covers Symbio 800; listening services per Ethernet port.
OI-02	Siemens	Desigo CC V9 SL-C per component requirement (certificate test report 713269126-02); Desigo CC OPC UA client support for the ControlLogix 5580 OPC UA server (security policies, certificate handling); current quality update.
OI-03	Rockwell	Impact of controller redundancy on the SL 1 certificate and compensations; ControlLogix 5580 OPC UA server firmware revision, security policies and session and tag limits; CIP Security support on the selected communication modules and PowerFlex 755T.
OI-04	Danfoss	FC 102 software version and CIP Security support on the MCA 121 EtherNet/IP option.
OI-05	Endress+Hauser	Security features and certification of the selected Proline transmitter.
OI-06	Cisco	Catalyst 9300 62443 certification status for the selected IOS-XE release.
OI-07	Fortinet	FortiOS 7.6 SL 4 certificate scope, models and conditions.
OI-08	Integrator	Refrigerant monitor and leak-detection panel make and model → new per-product checklist if not in the library.
OI-09	Integrator	Kepware version, drivers and licensing for the site and campus-wide historian path, and its capability per CR.
OI-10	Siemens	S7-1500 CPU model and firmware for the skid; Desigo PXC model and firmware; 62443 capability statements for both.
OI-11	Skid vendor	Make and model of skid remote I/O, dosing drives, PROFIBUS DP devices, DP/PA coupler and PA instruments, and their PROFINET Security Class support → new per-product checklists where not in the library.